

Báo cáo Lỗi, Khuyết tật & Bảo mật Ứng dụng (Full Bug & Vulnerability Report)

- Sinh viên:** Mai Thị Kim Duyên
- MSSV:** 23127185
- Hệ thống kiểm thử:** Backend EShop SUT (`http://localhost:3000`)
- Nguồn dữ liệu:** Dữ liệu thực thi JMeter (`jmeter/results/`), HTML Dashboard Report và rà soát mã nguồn Backend (`eshop-sut/backend/server.js`).

Phần 1: Phân tích Vấn đề Hiệu năng & Ảnh xạ GitHub Issues theo Sampler

Dựa trên phân tích từ dữ liệu log thô JTL, báo cáo HTML Dashboard và rà soát mã nguồn hệ thống:

Sampler / Transaction	Load Avg (ms)	Load P95 (ms)	Stress Avg (ms)	Spike Avg (ms)	Nhận xét điểm nghẽn & Lỗi phát hiện	GitHub Issue Link
Register	41.50	51.45	8.60	12.10	Nghẽn đĩa Ghi (Write-heavy): Độ trễ cao nhất hệ thống do SQLite ghi đĩa <code>INSERT INTO users</code> đồng bộ.	#12
Login	1.70	2.00	1.50	1.50	Lỗi Logic Đăng nhập: Đăng nhập thất bại tăng +2 lần thử và khóa tài khoản 180s.	#13
Categories	0.90	1.90	0.80	0.80	Baseline Hiệu năng & Khuyến nghị Caching: Response nhanh (< 1.5ms), đề xuất thêm Redis Cache cho scale lớn.	#20
ProductList	0.70	1.00	0.70	0.90	Lỗi Bảo mật SQL Injection trong ô tìm kiếm & Lỗi Kiểu dữ liệu Giá sản phẩm ID chẵn.	#16 , #18
ProductDetail	1.10	2.00	0.90	0.60	Lỗi Bất đồng nhất Kiểu dữ liệu Giá sản phẩm (String vs Number).	#18
AddToCart	0.90	1.00	0.90	1.00	Giám sát Trạng thái In-memory: Đề xuất chuyển giỏ hàng sang Redis để mở rộng hệ thống (Horizontal Scale).	#21

ApplyCoupon	1.30	2.00	0.90	1.20	Lỗi Công thức giảm %, Ngưỡng min sai & Thiếu Middleware xác thực.	#14 , #15
Checkout	34.70	54.70	2.90	3.40	Nghẽn đĩa Ghi (Write-heavy) & Lỗi hồng Tin tưởng total_amount từ Client (Price Tampering).	#12 , #15
Orders	1.30	2.00	0.80	1.10	Lỗi Chuyển trạng thái đơn Canceled -> Delivered & Hủy đơn khi đang Shipping.	#19

Phần 2: Bảng Tổng quan 11 Bug & Lỗi hồng Bảo mật trong SUT

STT	Tên Bug / Lỗi hồng	Phân loại	Vị trí Code	Mức độ	GitHub Issue Link
1	Nghẽn I/O đĩa synchronous SQLite	Performance	database.js & server.js	High	#12
2	Lỗi hồng SQL Injection trong Tìm kiếm	Security	server.js (dòng 143-151)	Critical	#16
3	Lỗi hồng Leo thang đặc quyền (Privilege Escalation)	Security	server.js (dòng 118-128)	Critical	#17
4	Tin tưởng total_amount từ Client (Price Tampering)	Security	server.js (dòng 297)	Critical	#15
5	Thiếu Middleware xác thực API Coupon	Security	server.js (dòng 363)	High	#15
6	Bộ đếm lần đăng nhập sai & thời gian khóa bị lặp	Logic	server.js (dòng 54-58)	High	#13
7	Công thức tính giảm giá phần trăm bị sai	Logic	server.js (dòng 400, 420)	High	#14
8	So sánh ngưỡng tối thiểu Coupon sai bất đẳng thức	Logic	server.js (dòng 379)	Medium	#14
9	Cho phép chuyển trạng thái đơn Canceled -> Delivered	Logic	server.js (dòng 551)	High	#19
10	Cho phép Hủy đơn hàng đang trong trạng thái Shipping	Functional	server.js (dòng 328-331)	Medium	#19
11	Bất đồng nhất kiểu dữ liệu Giá sản phẩm (Type Mismatch)	Functional	server.js (dòng 162-164)	Medium	#18

Phần 3: Chi tiết 11 Bug & Lỗ hổng Bảo mật

Bug 1: Nghẽn I/O đĩa synchronous SQLite (Performance)

- **Phân loại:** Performance
 - **Mức độ:** High
 - **GitHub Issue Link:** [#12](#)
 - **Vị trí Source Code:** `database.js` & `server.js`
 - **Hành vi Kỳ vọng:** Thao tác ghi cơ sở dữ liệu bất đồng bộ không làm tắc nghẽn event loop.
 - **Hành vi Thực tế:** Các câu lệnh `INSERT INTO users` và `INSERT INTO orders` chạy ở chế độ ghi đĩa đồng bộ, khiến thời gian phản hồi của `Register` (41.5ms) và `Checkout` (34.7ms) chậm gấp 40 lần so với các request Read (< 1.5ms).
 - **Giải pháp Khắc phục:** Bật chế độ Write-Ahead Logging `PRAGMA journal_mode = WAL;` trong `database.js`.
-

Bug 2: Lỗ hổng SQL Injection trong Tìm kiếm Sản phẩm (Security)

- **Phân loại:** Security
 - **Mức độ:** Critical
 - **GitHub Issue Link:** [#16](#)
 - **Vị trí Source Code:** `server.js` (dòng 143-151)
 - **Hành vi Kỳ vọng:** Tham số tìm kiếm phải được escape và truyền qua Parameterized Query.
 - **Hành vi Thực tế:** Code nối chuỗi SQL trực tiếp: `LIKE '%${searchQuery}%'`. Kẻ tấn công có thể chèn cú pháp SQL để trích xuất toàn bộ dữ liệu bảng `users` hoặc xóa bảng.
 - **Giải pháp Khắc phục:** Đổi thành Parameterized Query: `db.all("SELECT * FROM products WHERE name LIKE ?", ['%' + searchQuery + '%'])`.
-

Bug 3: Lỗ hổng Leo thang đặc quyền Admin (Privilege Escalation)

- **Phân loại:** Security
 - **Mức độ:** Critical
 - **GitHub Issue Link:** [#17](#)
 - **Vị trí Source Code:** `server.js` (dòng 118-128)
 - **Hành vi Kỳ vọng:** Người dùng thông thường không được phép tự cập nhật trường `role` của chính mình.
 - **Hành vi Thực tế:** Route `PUT /api/users/me` cho phép nhận bất kỳ thuộc tính nào từ `req.body`. Kẻ tấn công chỉ cần gửi `{ "role": "admin" }` để tự thăng cấp tài khoản thành Admin.
 - **Giải pháp Khắc phục:** Tháo bỏ trường `role` khỏi danh sách các trường được phép cập nhật trong `PUT /api/users/me`.
-

Bug 4: Tin tưởng `total_amount` từ Client - Sửa giá đơn hàng (Price Tampering)

- **Phân loại:** Security
- **Mức độ:** Critical
- **GitHub Issue Link:** [#15](#)
- **Vị trí Source Code:** `server.js` (dòng 297)
- **Hành vi Kỳ vọng:** Backend phải tự tính toán tổng tiền đơn hàng dựa trên giá sản phẩm lưu trong CSDL.
- **Hành vi Thực tế:** Route `POST /api/checkout` nhận trực tiếp `total_amount` từ `req.body` do client gửi lên và lưu trực tiếp vào bảng `orders`. Kẻ tấn công có thể mua hàng trị giá hàng chục triệu với giá 0 VND.

- **Giải pháp Khắc phục:** Tính toán lại tổng số tiền trên Server: truy vấn giá từng mặt hàng từ DB và nhân với số lượng.
-

Bug 5: Thiếu Middleware Xác thực API Áp dụng Mã giảm giá (Security)

- **Phân loại:** Security
 - **Mức độ:** High
 - **GitHub Issue Link:** [#15](#)
 - **Vị trí Source Code:** `server.js` (dòng 363)
 - **Hành vi Kỳ vọng:** Yêu cầu người dùng phải đăng nhập (`authenticateToken`) mới được áp dụng coupon.
 - **Hành vi Thực tế:** Route `POST /api/apply-coupon` không sử dụng middleware `authenticateToken` , cho phép đối tượng ẩn danh gửi request áp mã coupon liên tục.
 - **Giải pháp Khắc phục:** Bổ sung middleware `authenticateToken` vào định nghĩa route `POST /api/apply-coupon` .
-

Bug 6: Bộ đếm lần đăng nhập sai & Thời gian khóa bị lặp (Logic)

- **Phân loại:** Logic
 - **Mức độ:** High
 - **GitHub Issue Link:** [#13](#)
 - **Vị trí Source Code:** `server.js` (dòng 54-58)
 - **Hành vi Kỳ vọng:** Tăng 1 lần thử sai cho mỗi lượt đăng nhập lỗi (`attempts + 1`); khóa 30 giây sau 3 lần sai.
 - **Hành vi Thực tế:** Code tăng `login_attempts + 2` cho mỗi lần sai và thiết lập thời gian khóa `180000 ms` (180 giây). Người dùng chỉ cần gõ sai 2 lần là bị khóa tài khoản trong 3 phút.
 - **Giải pháp Khắc phục:** Sửa thành `login_attempts + 1` và thời gian khóa `30000 ms` .
-

Bug 7: Công thức tính giảm giá Coupon Phần trăm bị sai (Logic)

- **Phân loại:** Logic
 - **Mức độ:** High
 - **GitHub Issue Link:** [#14](#)
 - **Vị trí Source Code:** `server.js` (dòng 400, 420)
 - **Hành vi Kỳ vọng:** Số tiền giảm = `total_amount * (discount_value / 100)` .
 - **Hành vi Thực tế:** Code tính toán: `total_amount * (1 - discount_value)` . Nếu mã giảm 10% (`discount_value = 10`), hệ thống sẽ tính số tiền được giảm = `total * (1 - 10) = -9 * total` (hoặc giảm tới 90% tổng tiền).
 - **Giải pháp Khắc phục:** Đổi công thức thành `discountAmount = total_amount * (coupon.discount_value / 100)` .
-

Bug 8: So sánh Ngưỡng tối thiểu Mã giảm giá sai Bất đẳng thức (Logic)

- **Phân loại:** Logic
- **Mức độ:** Medium
- **GitHub Issue Link:** [#14](#)
- **Vị trí Source Code:** `server.js` (dòng 379)
- **Hành vi Kỳ vọng:** Đơn hàng có giá trị bằng hoặc lớn hơn mức tối thiểu (`>= min_order_amount`) được áp dụng mã.
- **Hành vi Thực tế:** Code sử dụng phép so sánh nghiêm ngặt `total_amount > min_order_amount` . Nếu đơn hàng có tổng tiền đúng bằng giá trị tối thiểu quy định, hệ thống sẽ báo lỗi không đủ điều

kiện.

- **Giải pháp Khắc phục:** Đổi phép so sánh từ `>` thành `>=`.

Bug 9: Cho phép Chuyển trạng thái Đơn hàng từ Canceled sang Delivered (Logic)

- **Phân loại:** Logic
- **Mức độ:** High
- **GitHub Issue Link:** [#19](#)
- **Vị trí Source Code:** `server.js` (dòng 551)
- **Hành vi Kỳ vọng:** Đơn hàng đã ở trạng thái Đã hủy (`canceled`) không được phép chuyển sang Đã giao (`delivered`).
- **Hành vi Thực tế:** Mã nguồn có dòng kiểm tra: `if (currentStatus === "canceled" && status === "delivered") isValidTransition = true;` , cho phép khôi phục và giao đơn hàng đã bị hủy.
- **Giải pháp Khắc phục:** Loại bỏ điều kiện trên khỏi máy trạng thái cập nhật đơn hàng.

Bug 10: Cho phép Hủy đơn hàng đang trong Trạng thái Shipping (Functional)

- **Phân loại:** Functional
- **Mức độ:** Medium
- **GitHub Issue Link:** [#19](#)
- **Vị trí Source Code:** `server.js` (dòng 328-331)
- **Hành vi Kỳ vọng:** Người dùng chỉ được hủy đơn hàng ở trạng thái `pending` hoặc `confirmed` .
- **Hành vi Thực tế:** Khối `if` hủy đơn hàng bỏ quên kiểm tra trạng thái `shipping` , cho phép người dùng tự hủy đơn khi hàng đang được vận chuyển.
- **Giải pháp Khắc phục:** Bổ sung điều kiện chặn hủy đơn hàng khi trạng thái là `shipping` hoặc `delivered` .

Bug 11: Bất đồng nhất Kiểu dữ liệu Giá sản phẩm (Data Type Mismatch)

- **Phân loại:** Functional
- **Mức độ:** Medium
- **GitHub Issue Link:** [#18](#)
- **Vị trí Source Code:** `server.js` (dòng 162-164)
- **Hành vi Kỳ vọng:** Thuộc tính `price` của sản phẩm luôn trả về kiểu dữ liệu số (`Number`).
- **Hành vi Thực tế:** Code thực hiện ép kiểu: `if (row.id % 2 === 0) row.price = row.price.toString()` . Các sản phẩm có ID chẵn trả về chuỗi String, ID lẻ trả về số Number, gây lỗi parse trên Frontend và các công cụ kiểm thử tự động.
- **Giải pháp Khắc phục:** Loại bỏ dòng ép kiểu chuỗi giả định, giữ nguyên giá trị `Number(row.price)` .

Phần 4: Phụ lục Tối ưu & Khuyến nghị Khắc phục (Remediation)

1. **Bảo mật cơ sở dữ liệu:** Áp dụng Parameterized Query cho tất cả các câu lệnh SQL để triệt phá lỗ hổng SQL Injection.
2. **Quản lý quyền truy cập:** Loại bỏ thuộc tính `role` khỏi các API cập nhật thông tin cá nhân của Client.
3. **Tính toán Phía Server:** Luôn tính toán lại tổng tiền đơn hàng và giá trị giảm giá trên Server, không bao giờ tin tưởng dữ liệu giá gửi từ Client.
4. **Tối ưu I/O cơ sở dữ liệu:** Cấu hình SQLite ở chế độ Write-Ahead Logging (`PRAGMA journal_mode = WAL;`) để giảm độ trễ ghi đĩa của `Register` và `Checkout` .